

Aviation-Grade Security

When security is not an option - but a necessity



Lufthansa
Industry Solutions

BOSIDES
FRANKFURT

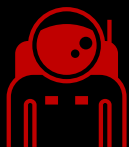


WELCOME TO HYBRID HELL

BREAKING ENTERPRISE IDENTITY
BEYOND ACTIVE DIRECTORY



WHO THE HELL AM I



Expert Offensive Security Consultant
Lufthansa Industry Solutions



10+ years Offensive Security & Red Teaming
Across Europe & APAC



Government & Enterprise Environments
Highly Regulated Industries



Research & Innovation
AI systems · Building Supervised Red-team Agents



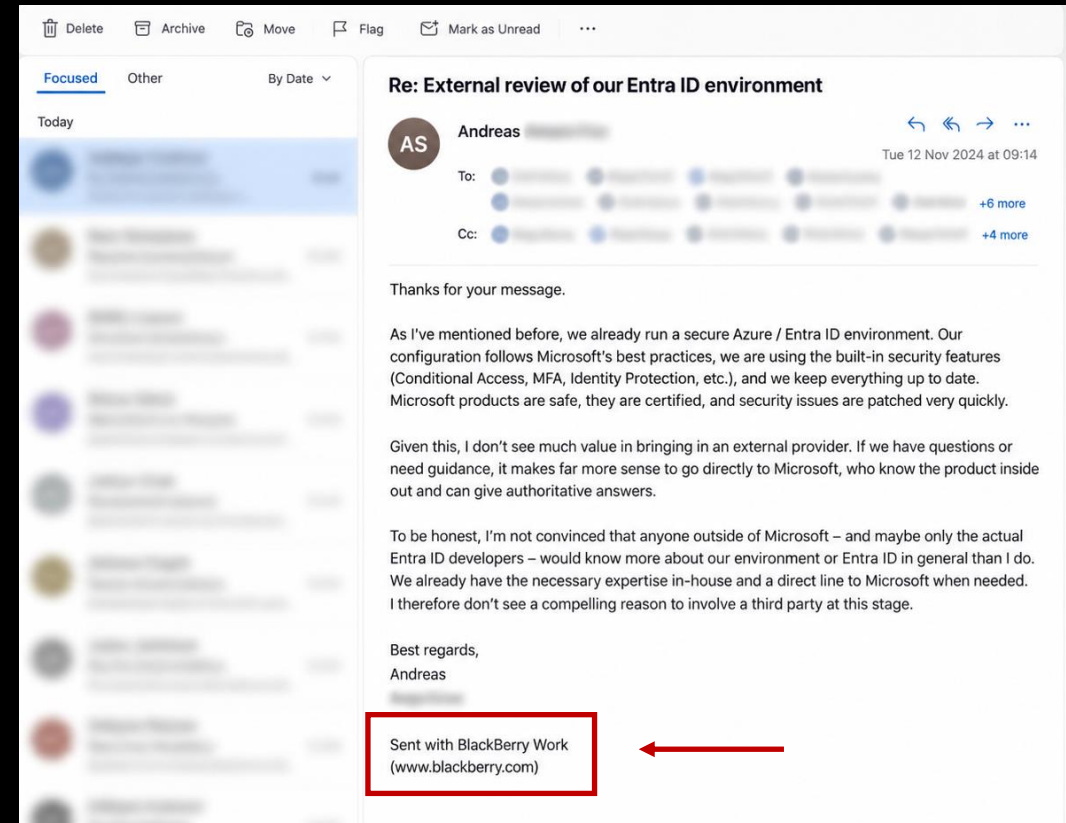
YOU WORK FOR LUFTHANSA.

“We need someone who understands Microsoft.”

THE DETAIL IN THE EMAIL.

The message challenged
our expertise.

The footer raised
a different question.



SENT FROM BLACKBERRY

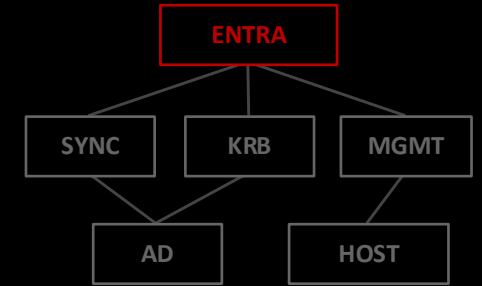
Not an exploit

A reason to examine an exception



WHAT COUNTS AS PROOF

TRUST MAP



THREE SYSTEMS. THREE AUTHORITIES.

A login is not a permission.

— Active Directory

Domain objects and on-premises access

— Entra ID

Directory roles and cloud identities

— Azure

Resource permissions at an explicit scope

SYSTEM	AUTHORITY	SCOPE
 Active Directory	Domain Admin	 Domain
 Entra ID	Global Administrator	 Tenant / AU / Object
 Azure RBAC	Subscription Owner	 Management group / Subscription / Resource group / Resource

Domain Admin ≠ Global Administrator ≠ Subscription Owner

HYBRID IS A TRUST MAP.

Different places Connected decisions

— Authentication

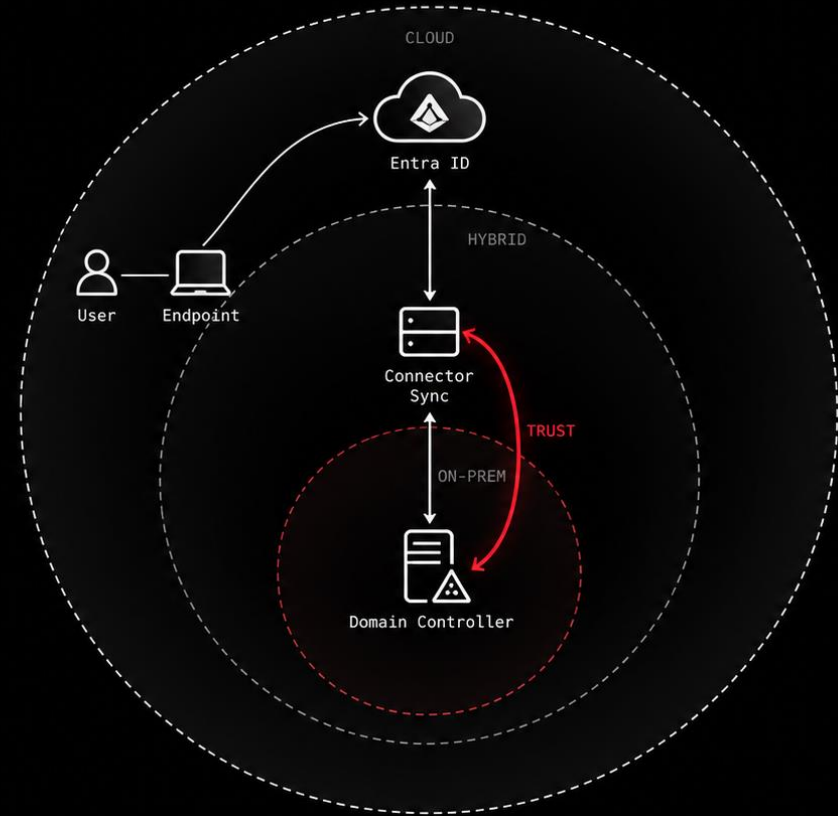
Which system can vouch for an identity?

— Synchronization

Which system controls the source data?

— Management

Which service can act on a machine?



Every arrow is a question about authority.

Hybrid Sign-in. Three ways

01

PHS

Password Hash Synchronization



Derived hash; Entra checks password.

BENEFIT

Simple; no live AD dependency for the password check.

TRADE-OFF

Cloud-stored verifier;
AD state is not checked live.

02

PTA

Pass-through Authentication



Agent asks AD to check the password.

BENEFIT

Current AD account policies;
no hash sync required.

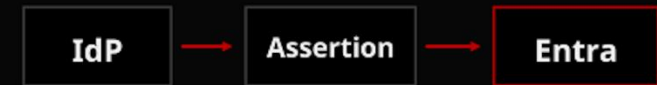
TRADE-OFF

Requires available agents,
domain controllers and network.

03

FEDERATION

AD FS / external identity provider



External IdP validates; Entra trusts proof.

BENEFIT

Reuse a trusted IdP;
support specific auth needs.

TRADE-OFF

More complexity;
protect token-signing keys.

AN ARROW NEEDS EVIDENCE.

Say what you can prove.
Label the rest.

- **Identity**

Object ID and tenant—not a role label

- **Permission + scope**

The actual operation, at the actual scope

- **Preconditions**

What must already be true

☐ IDENTITY Which principal? _____ SUBJECT / TENANT / OBJECT ID	 EVIDENCE REQUIRED —
☒ AUTHORITY Which operation and scope? _____ OPERATION / SCOPE / EFFECTIVE RIGHTS	 EVIDENCE REQUIRED —
☐ PRECONDITIONS Which required conditions? _____ STATE / CONFIGURATION / CONTEXT	 EVIDENCE REQUIRED —

Missing a field? The path stays unconfirmed. That is a result.

CONDITIONAL ACCESS IS CONTEXT.

“We have MFA”
is not the whole answer.

- **Who + what**
User, client and target resource
- **Under which conditions**
Device, location, risk and exclusions
- **Which outcome**
Block, grant and session controls



A policy name is not evidence of effective coverage.

THE BLACKBERRY WAS NOT THE BUG.

The clue pointed to a policy gap.

— Starting condition

An identity or session was required

— Finding

Intended control versus actual result

— Impact

Prove resource permissions separately



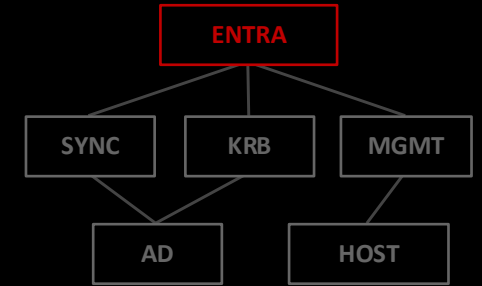
Historical finding. Not a universal 2026 MFA bypass

WHO

IS ASKING

FOR WHAT?

TRUST MAP



THE APP IS NOT THE RESOURCE.

One sign-in. Three questions.

— User

Who authenticated? oid / tid

— Client

Which app requested access? appid / azp

— Resource

Target API: aud. Delegated scopes: scp.

SIGN-IN EVENT Success 2024-11-14 10:27:31Z ...

**USER / SUBJECT**
Same principal and tenant

oid

a1b2c3d4-e5f6-7890-abcd-ef1234567890

tid

72f988bf-86f1-41af-91ab-2d7cd011db47

upn

alice@contoso.com

type

User

**CLIENT**
Microsoft Teams

appid

1fec8e78-bce4-4aaf-ab1b-5451cc387264

azp

1fec8e8f-86e4-4aaf-9b1b-5451cc387264

app

Microsoft Teams

type

Public client

**RESOURCE**
Exchange Online

aud

00000002-0000-0ff1-ce00-000000000000

scp

Mail.Read

type

API

name

Microsoft Exchange Online

**CLIENT**
Azure Portal

appid

04b07795-8ddb-461a-bbee-02f9e1bf7b46

azp

04b07795-8ddb-461a-bbee-02f9e1bf7b46

app

Microsoft Azure Portal

type

Public client

**RESOURCE**
Microsoft Graph

aud

00000003-0000-0000-c000-000000000000

scp

User.Read

type

API

name

Microsoft Graph

An app name is not the whole access story

USING A TOKEN. RENEWING ACCESS.

Possession is not permanent access

— Use

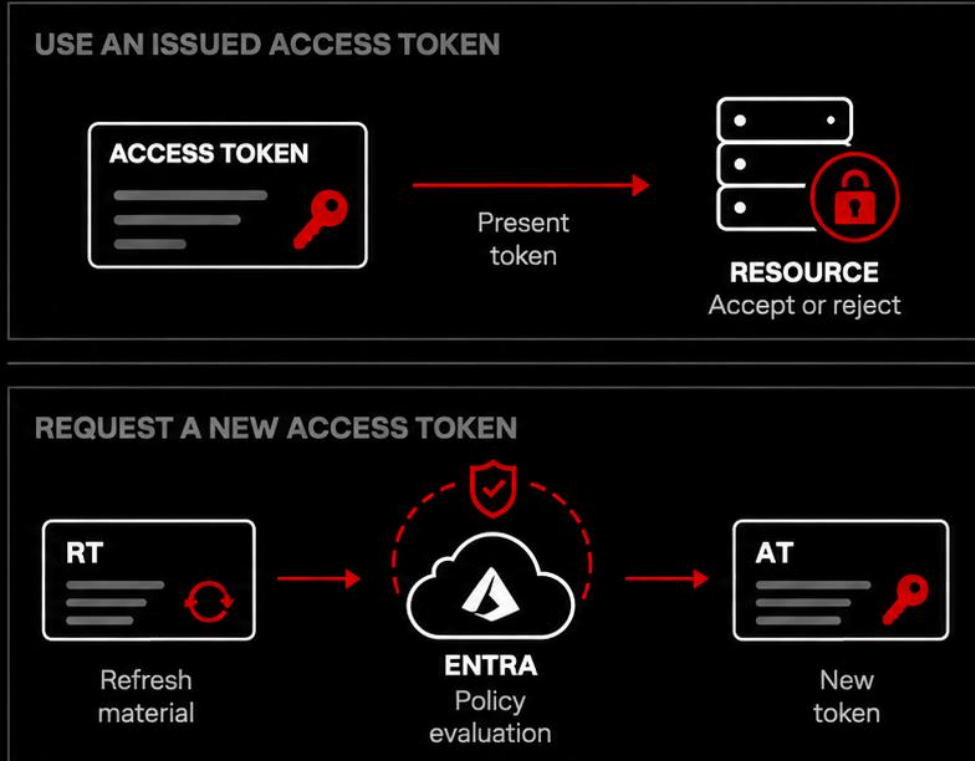
Present an access token to its resource

— Renew

Ask Entra to issue another access token

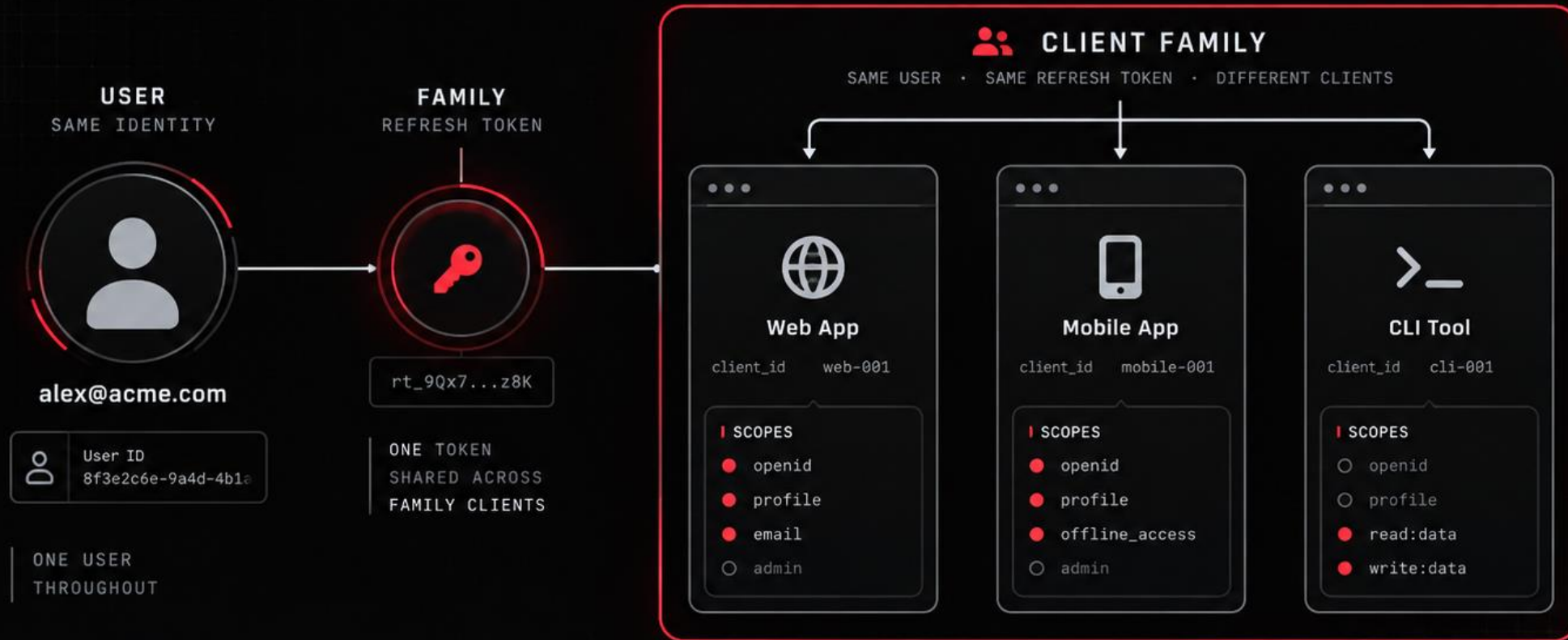
— Evaluate

Renewal still faces applicable access policy



A resource change is not a client change

FOCI - ONE FAMILY. DIFFERENT CLIENTS



SAME USER. DIFFERENT SCOPES

ILLUSTRATIVE CLAIM COMPARISON · NOT LIVE TOKENS OR CUSTOMER EVIDENCE

Read what changed.
Read what did not.

- **Held constant**

Tenant, user and chosen resource API

- **Changed**

The requesting client and delegated scopes

- **Interpret carefully**

Separate issuance — not editing a signed token

CLAIM	TOKEN A	TOKEN B
tid	TENANT_1	TENANT_1
oid	USER_1	USER_1
aud	RESOURCE_1	RESOURCE_1
appid / azp	CLIENT_A	CLIENT_B
scp	SCOPE_SET_A	SCOPE_SET_B

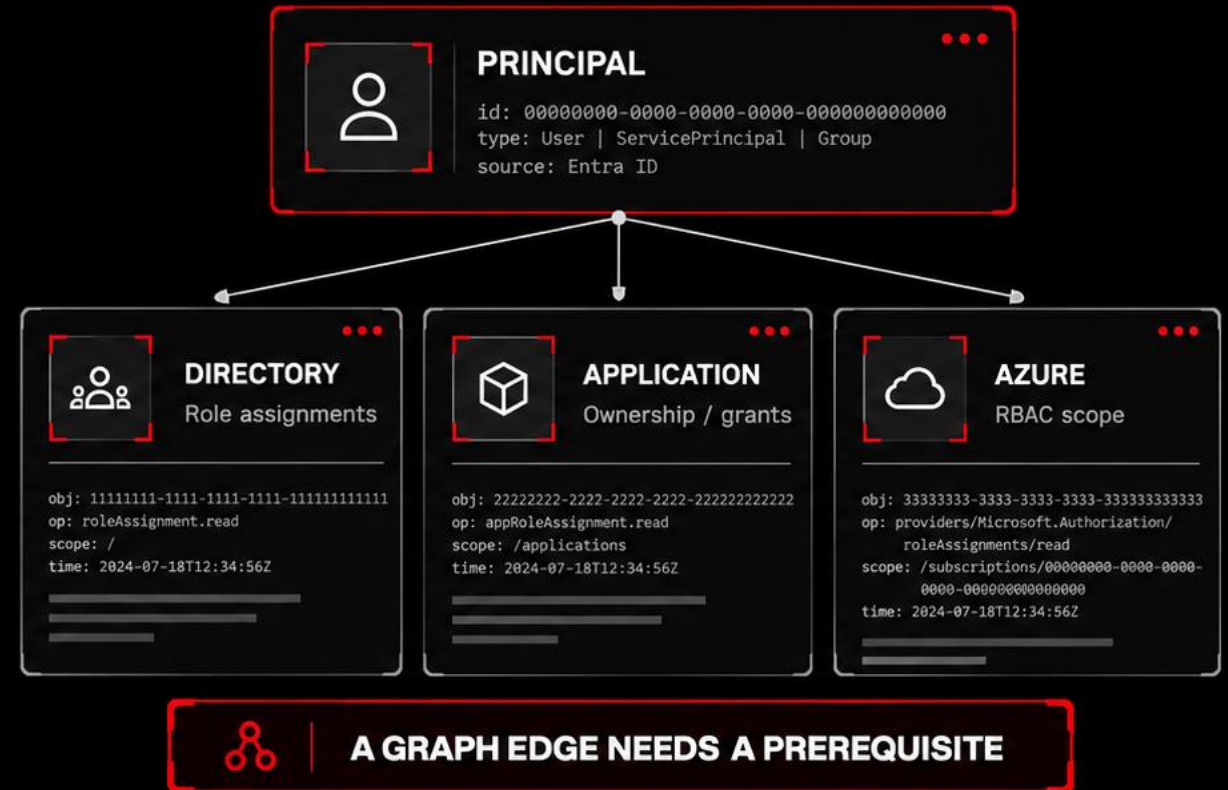
Schematic only. Capture a sanitized lab pair for evidence.

The evidence is in the difference — and the boundary.

WHO AM I? AT WHAT SCOPE?

Authority before attack narrative.

- **Assignments**
Direct, inherited and group-mediated rights
- **State**
Active / eligible; scope / conditions
- **Evidence**
Object ID + operation + scope + timestamp



Do not infer a whole path from one administrator label.

THE MANAGEMENT Cross the Line

**“Our servers
are on-premises.”**

- **Azure virtual machines**
Guest-management capabilities
- **Azure Arc**
Cloud-managed external servers
- **Intune**
Management of targeted, enrolled endpoints

Physical location is not a management boundary.



CLOUD PERMISSION. LOCAL PRIVILEGE

The interesting part
is the translation.

- Cloud authorization

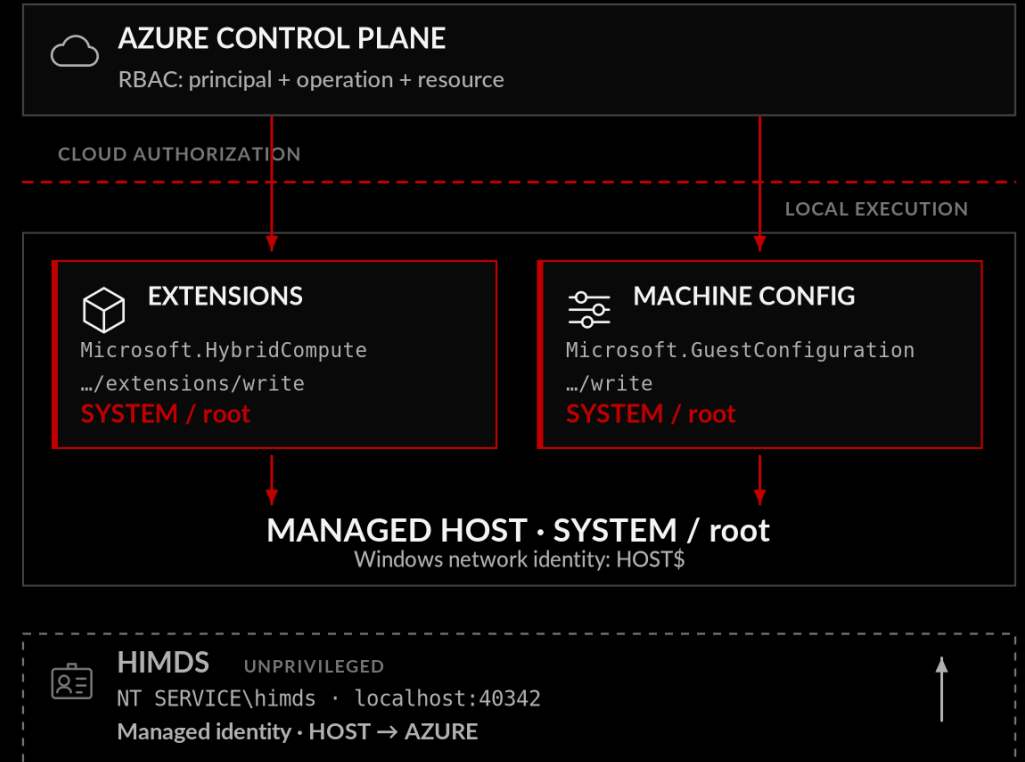
Two providers, two permissions

- Local enforcement

The allowlist covers extensions only

- Execution context

SYSTEM locally, HOST\$ on the network



Arc HIMDS is not the privileged extension manager.

STORM-2949: THE BOUNDARY THAT HELD.

A real management-plane incident.

- **Observed**

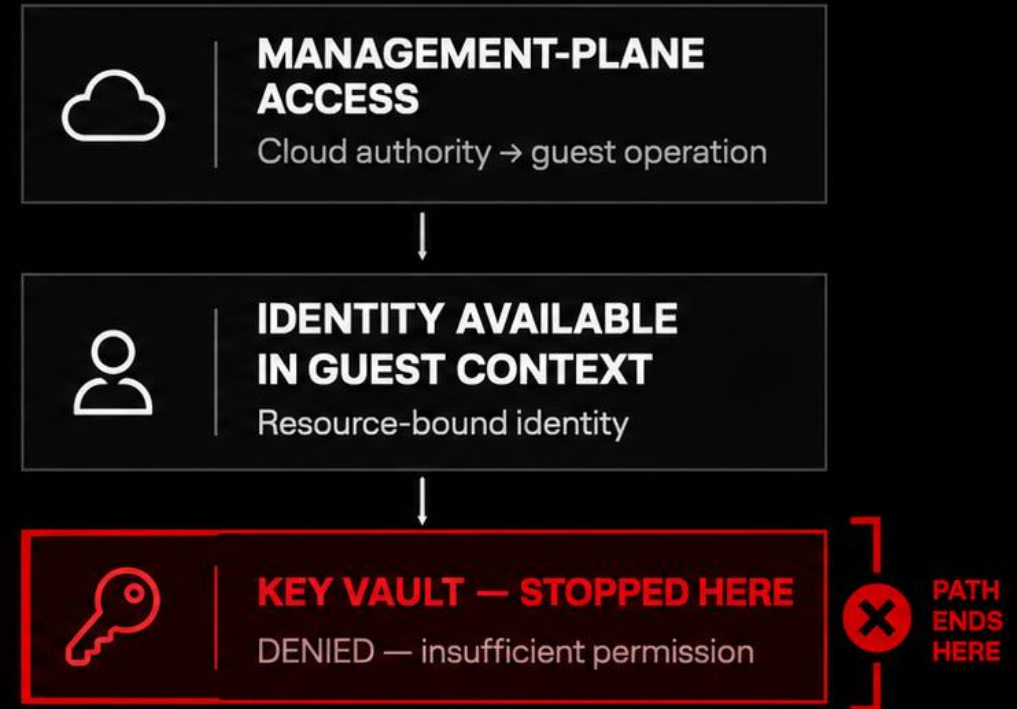
Privileged identities and Azure RBAC

- **Observed**

Legitimate VM-management features misused

- **Blocked**

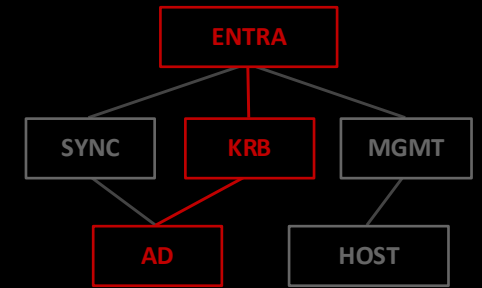
The next permission was missing.



A reachable identity is not automatically useful authority.

WHO VOUCHES FOR WHOM?

TRUST MAP



KERBEROS. WITH CLOUD PARTICIPATION.

Explain the normal flow first.

— Cloud stage

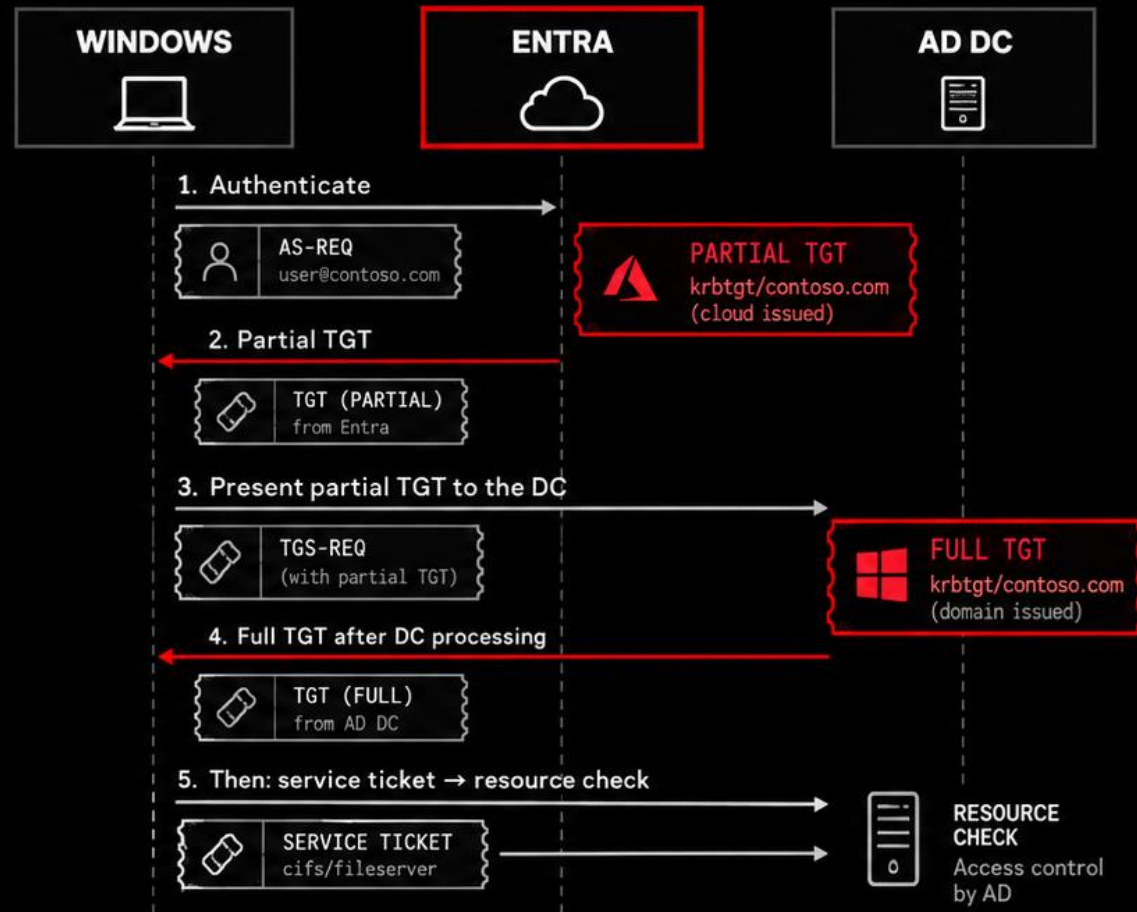
Authentication yields a partial TGT.

— Domain stage

The DC completes the ticket flow.

— Resource stage

AD still determines resource authorization.



AZUREADKERBEROS. NOT ANOTHER SERVER.

An AD representation of a trust relationship.

— Object

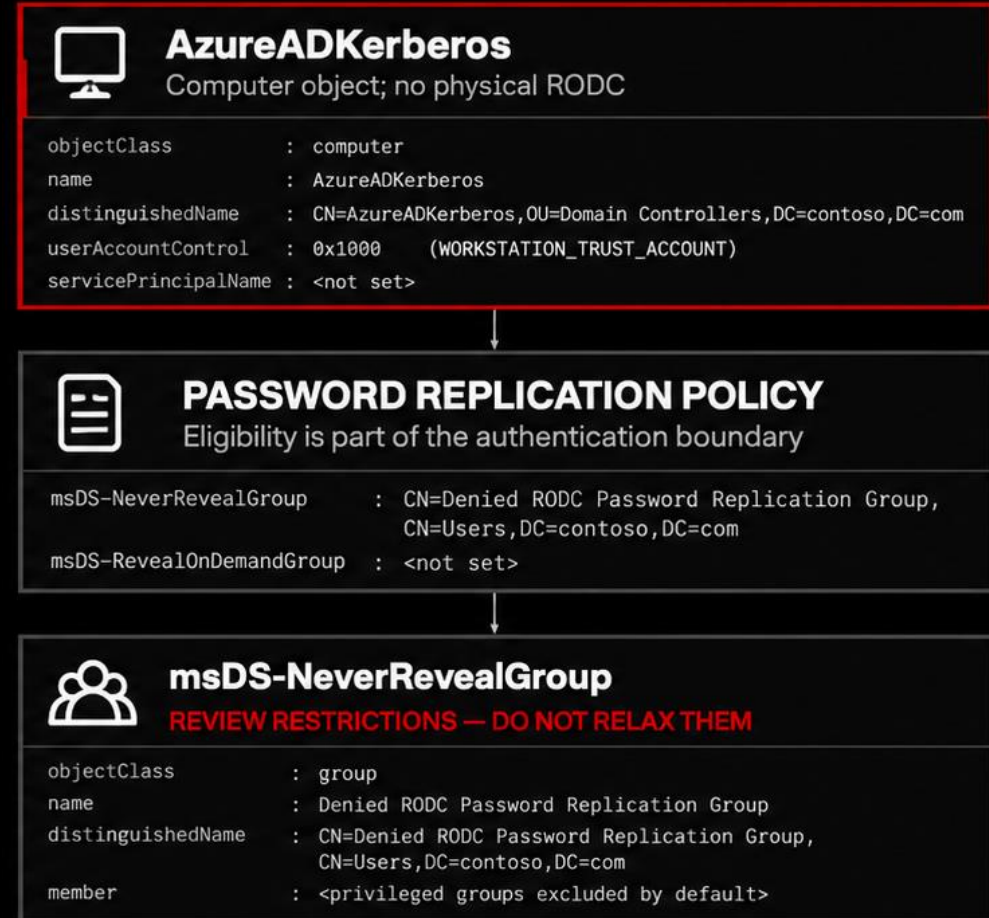
AzureADKerberos in the domain-controller OU.

— Restrictions

RODC-style password replication policy.

— Boundary

Default restrictions exclude privileged groups.



GLOBAL ADMIN $\neq$ DOMAIN ADMIN.

A research result is not a universal rule.

— Architecture

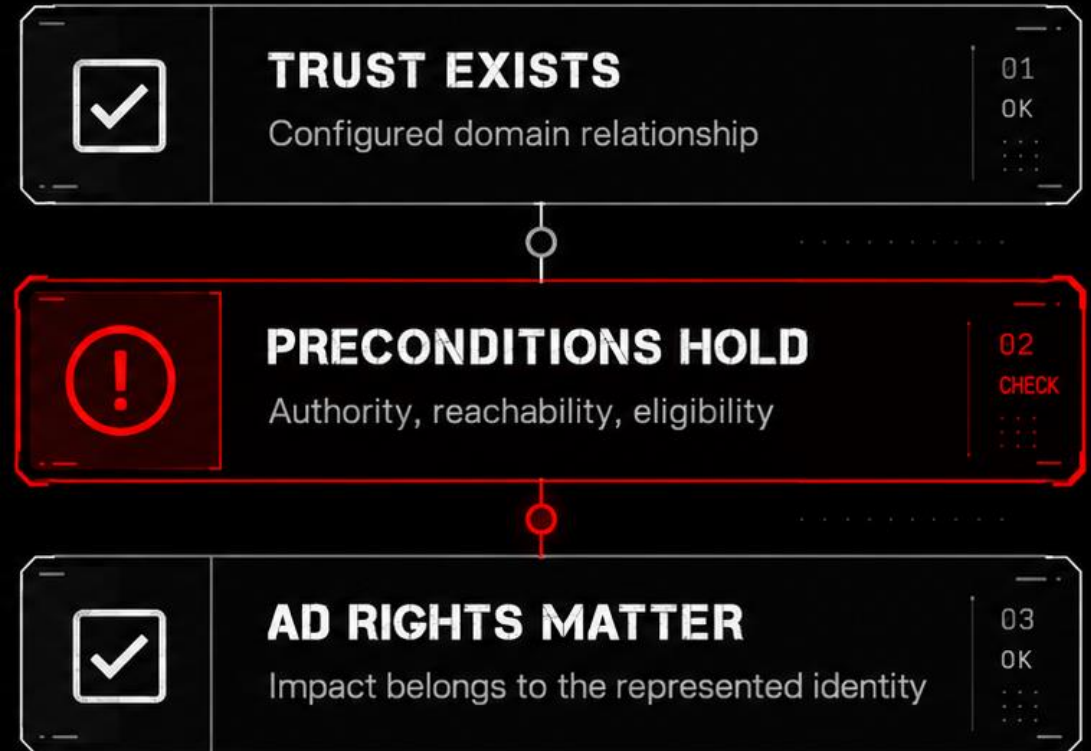
The trust must exist in this environment.

— Authority

Required cloud control and reachable DC.

— Identity

Eligible principal; actual AD permissions.



Keep the preconditions on screen, not in the footnotes.

TURN THE ARROW AROUND.

What can the old environment
tell the new one?



ENTRA CONNECT IS IDENTITY INFRASTRUCTURE.

**Do not collapse
three identities into one.**

- **AD DS connector**
AD rights depend on configured features.
- **Sync runtime**
Runs the engine and accesses its database.
- **Cloud connector**
Authenticates synchronization to Entra ID.

AD DS CONNECTOR



ADSYNC RUNTIME

Server / service / database boundary



CLOUD SYNC IDENTITY

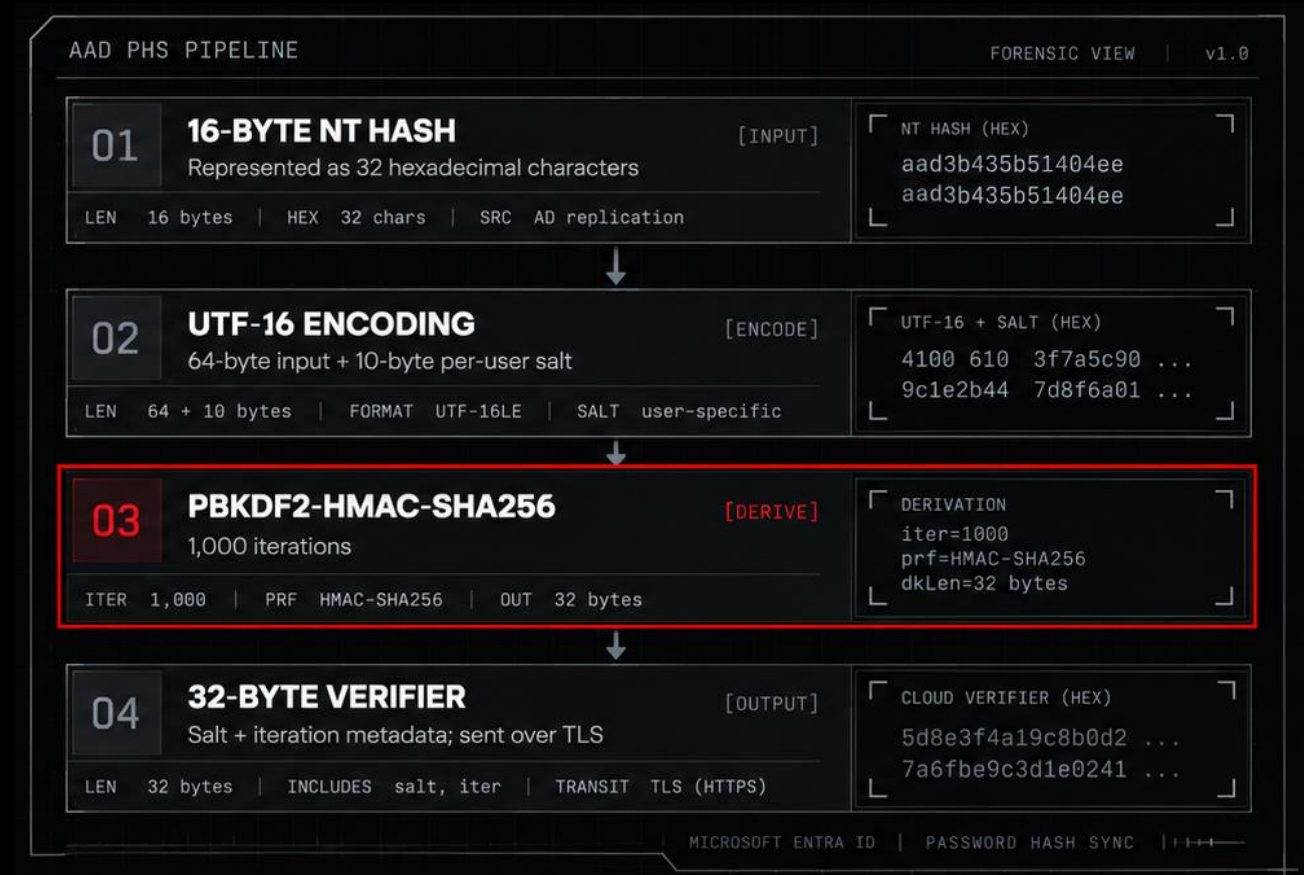
Legacy account or application/certificate mode

Check the deployed build and actual authentication mode.

PASSWORD HASH SYNC. NOT NTLM IN THE CLOUD.

One layer deeper than “hashes sync”.

- **Input**
The AD hash is retrieved via replication.
- **Transformation**
Encoding, salt and further derivation.
- **Output**
A cloud verifier, not the original NT hash.



STORM-0501: THE POLICY WAS SATISFIED.

An observed
on-premises → cloud path.

Identity

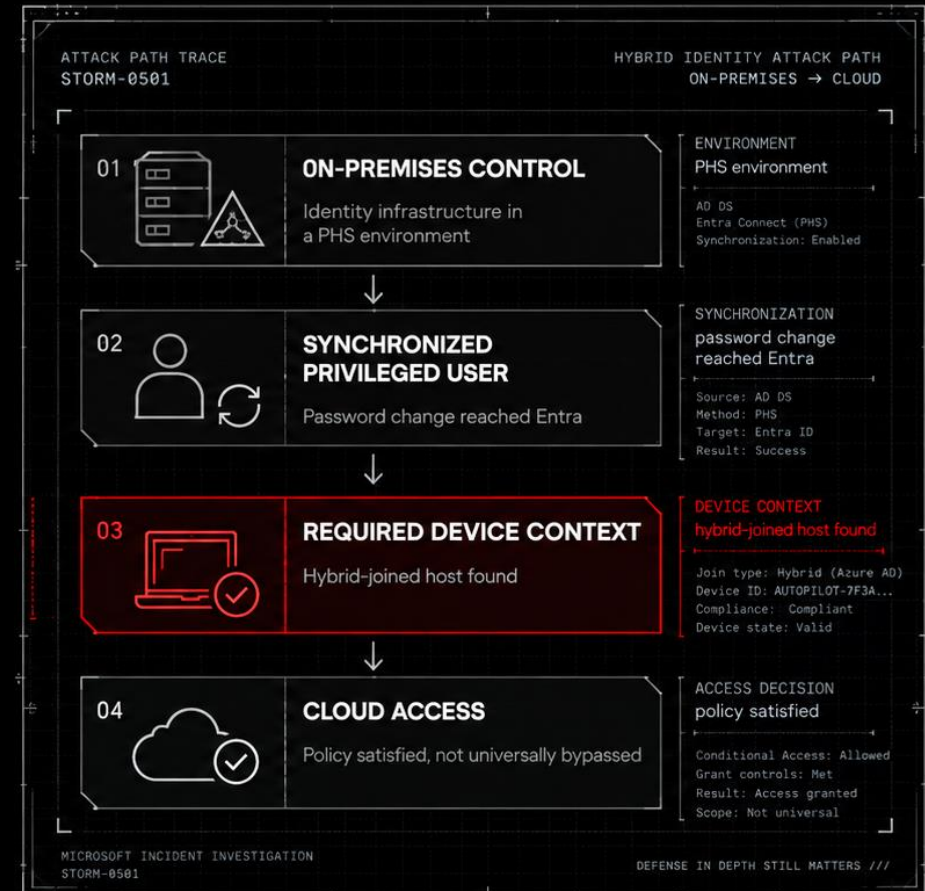
A privileged synchronized user bridged AD.

Device

Initial attempts failed the device policy.

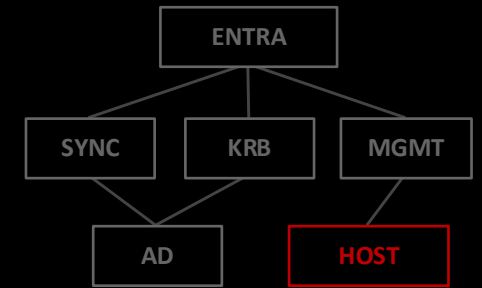
Outcome

A qualifying hybrid host enabled access.



AFTER
STRONG
AUTHENTICATION.

TRUST MAP



ONE WINDOWS SESSION. TWO SSO ROUTES

Native applications are not browsers

- **CloudAP**

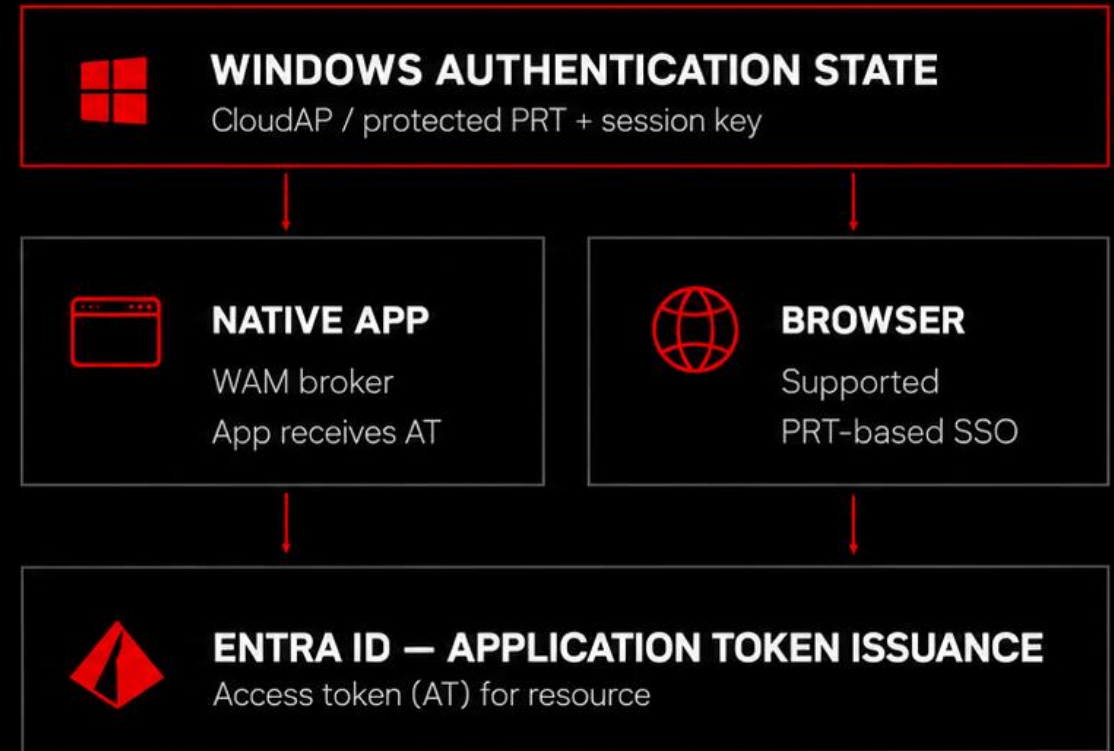
Windows authentication and protected PRT state.

- **Native app**

WAM brokers the application's token request.

- **Browser**

Supported browser SSO uses Windows authentication state.



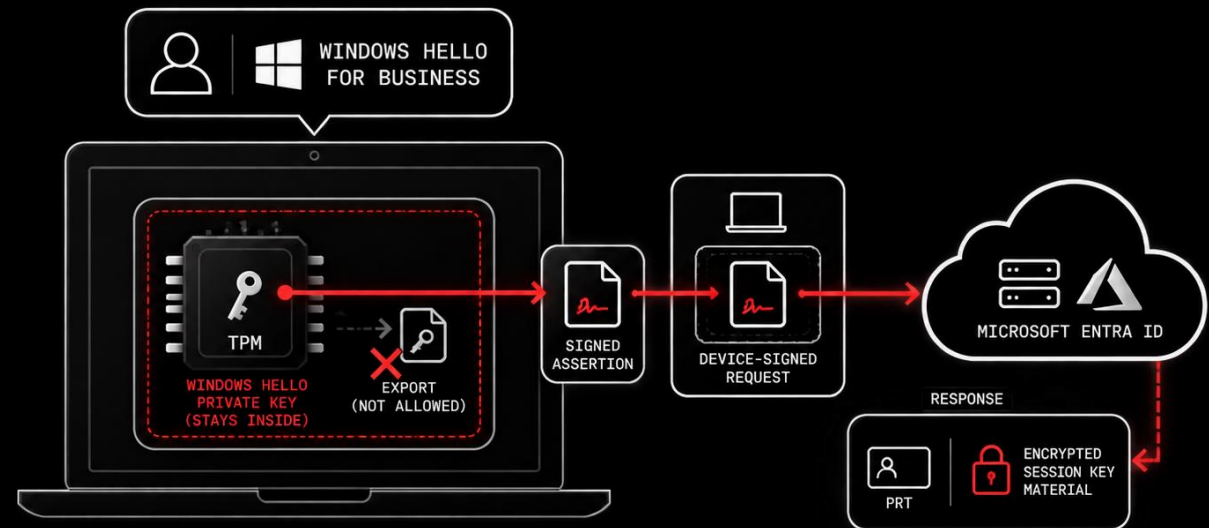
The app gets an access token. Not the PRT or its key.

WINDOWS HELLO. WHICH KEY SIGNS WHAT?

DEVICE KEY $\neq$ HELLO USER KEY $\neq$ PRT SESSION KEY

Protect the key. Examine its use.

- **Outer request**
Device certificate and signing context
- **Inner assertion**
Hello user key; tenant, time and nonce
- **Returned material**
PRT plus protected session-key material



Non-exportable $\neq$ non-usable

WE RESET
HIS PASSWORD.

ARE WE OUT?

ONE INCIDENT. SEVERAL LOG SOURCES.

Join evidence,
not just alerts.

Identity

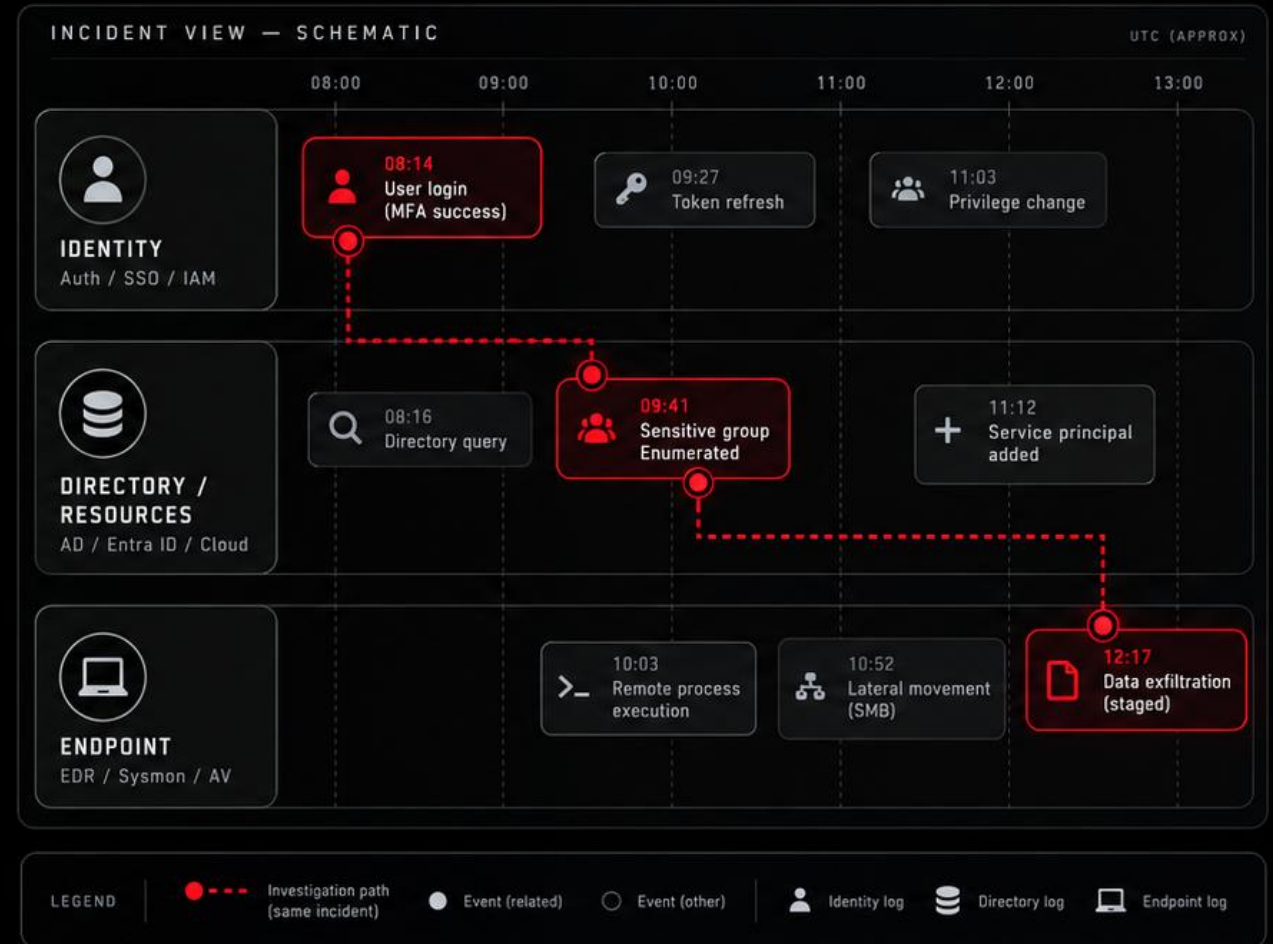
Sign-in result, principal and device

Control plane

Directory changes and Azure operations

Endpoint

Agent activity, account and host state



HUNT MANAGEMENT OPERATIONS.

A starting query.

Not a detection verdict.

- **Coverage**

Activity data must reach this workspace

- **Context**

Compare caller, operation, scope and status

- **Triage**

Correlate approval and endpoint evidence

```
AzureActivity
| where TimeGenerated > ago(7d)
| extend op = tolower(OperationNameValue)
| where op contains "runcommand"
      or op endswith "/extensions/write"
| project TimeGenerated, Caller, op,
      ActivityStatusValue,
      _ResourceId, CorrelationId
```

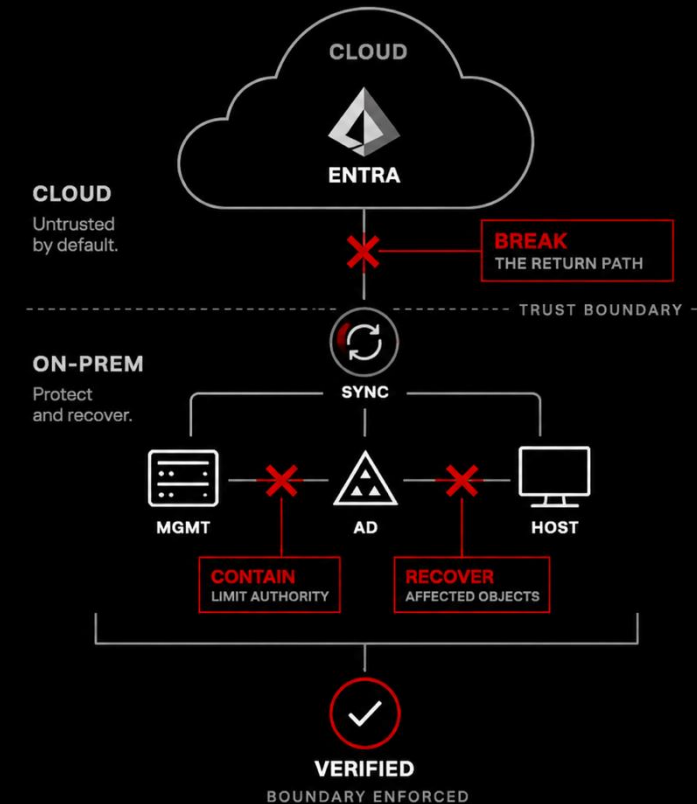
Expect benign administration. Investigate unexpected identity or scope

BREAK THE RETURN PATH.

Containment is a trust inventory.

- **Separate**
Independent cloud and AD administrators
- **Constrain**
Management scope and hybrid authority
- **Recover**
Affected credentials, sessions and trust

Fixing the entry point is necessary. It may not be sufficient



FIVE THINGS. THIS WEEK.

FIVE ACTIONS TIED TO THE PATHS IN THIS TALK

- 01 Separate cloud admin identities.**
Keep privileged Entra administration independent of synchronized accounts.
- 02 Audit Conditional Access exclusions.**
Include platform coverage and the unclassified platform.
- 03 Scope cloud-to-machine management.**
Arc, Run Command and Intune: only the machines that need it.
- 04 Protect AzureADKerberos restrictions.**
Review password replication policy. Do not relax it.
- 05 Use Token Protection where supported.**
Check the client, resource and device support matrix.

| **Then verify both sides — the allow and the deny.**

THE PLAYBOOK. TAKE THE METHOD HOME.

Understand the paths.
Assess your own.

- **Understand**

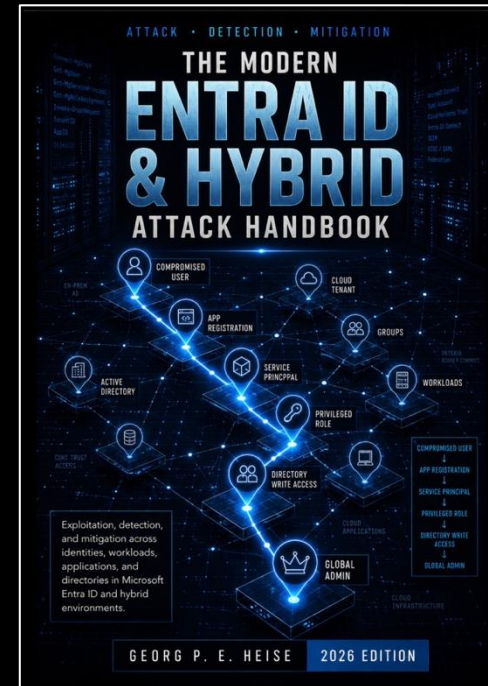
Techniques, prerequisites and normal trust flows.

- **Investigate**

Which conditions actually exist in your environment?

- **Act**

Evidence, detection and remediation guidance.

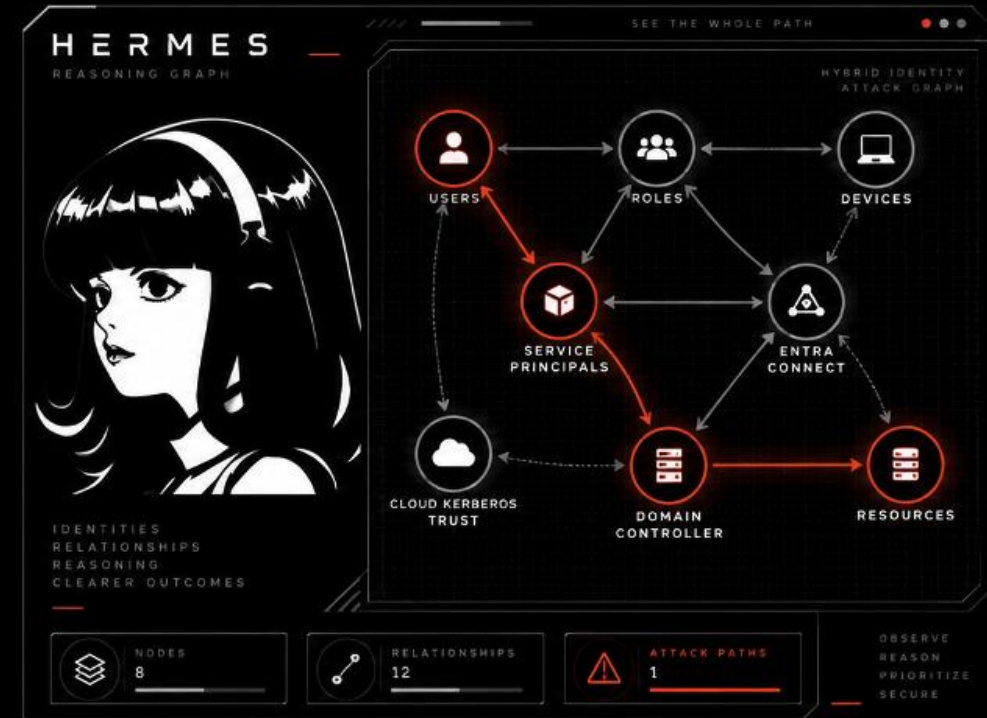


Understand the technique. Assess the exposure.

HERMES. TAKE THE PLAYBOOK HOME.

Understand the attacks. Assess your environment.

- **Built from the playbook**
Bring the assessment methodology into Hermes.
- **Applied to your environment**
Review identities, permissions and hybrid trust.
- **More than isolated findings**
Connect observations and prioritize what to examine.



github.com/gphehiese/AzureSecurity

Get the cloud skill + Entra ID / Hybrid Attack Playbook.

SENT FROM
BLACKBERRY

What does
the next system trust?



QUESTIONS ?

LET'S STAY IN TOUCH

SECURITY
PEOPLE
PROGRESS



TRUST
BUILDS
SAFER
TOMORROW

PASSENGER

GEORG HEISE

DESTINATION

Aviation-Grade Security

When security is not an option - but a necessity



**Lufthansa
Industry Solutions**

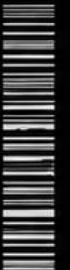
SCAN TO CONNECT



LinkedIn • Contact • Exchange



HAM
PEK
SYD
OOL
MEL
FRA



CYBER
TRAVELS
FURTHER

SAME MISSION. A SAFER TOMORROW.

Aviation-Grade Security

When security is not an option - but a necessity



Lufthansa
Industry Solutions

BOSIDES
FRANKFURT